CuraTrack: A Privacy-Preserving Multi-Agent Healthcare Coordination System for Unified Medical Records and Emergency Clinical Information Access

Mukesh V
Roll Number: 240701339
Department of Computer Science and Engineering
Rajalakshmi Engineering College
Chennai, Tamil Nadu, India

Mohamed Fayas MF
Roll Number: 240701340
Department of Computer Science and Engineering
Rajalakshmi Engineering College
Chennai, Tamil Nadu, India

Abstract

Medical information fragmentation across hospitals, clinics, diagnostic laboratories, paper prescriptions, and personal medical documents creates critical gaps in care. These gaps become life-threatening during emergencies when a patient is unconscious or otherwise unable to communicate known drug allergies, current medications, chronic conditions, previous diagnoses, and relevant treatment history. The problem is especially significant for individuals with chronic diseases who visit multiple healthcare providers over time. CuraTrack is a privacy-first, patient-centric healthcare coordination platform that consolidates patient-provided medical information into a structured longitudinal digital health profile and enables authorised healthcare professionals to retrieve relevant information when required under explicit consent or legitimate emergency use. Beyond passive record storage, the system introduces multiple specialised AI agents for data ingestion, medical-record structuring, medication monitoring, clinical risk-signal identification, emergency coordination, and clinician-facing summarisation, all governed by a deterministic Safety and Policy Layer that cannot be overridden by large-language-model (LLM) outputs. Voice-based prescription structuring, secure QR-mediated emergency access, and rural responder notification workflows incorporate human-in-the-loop confirmation and minimum-necessary disclosure. This paper presents a coherent research contribution: problem definition, literature-grounded motivation, multi-agent architecture with explicit agent contracts, deterministic safety design with detailed pseudocode, threat model aligned with India's Digital Personal Data Protection Act, 2023 (DPDP Act) and Ayushman Bharat Digital Mission (ABDM) principles, relational data model, implementation methodology, and a reproducible evaluation protocol using only synthetic or properly anonymised data. Features of the proposed architecture, features realised in any prototype, features under experimental evaluation, and features remaining as future work are explicitly distinguished. No claims of clinical effectiveness, reduced mortality, improved diagnostic accuracy, or production deployment success are made.

multi-agent systems, electronic health records, privacy-preserving healthcare, emergency medical access, deterministic safety layer, consent management, clinical information extraction, rural telehealth, ABDM, DPDP Act 2023, FHIR, human-in-the-loop, OCR, voice prescription

1 Introduction

The continuous, accurate, and timely availability of a patient's medical history is a foundational requirement of safe clinical care. In practice, medical information remains fragmented across hospitals, clinics, diagnostic laboratories, paper prescriptions, imaging archives, and patient-held documents. Each encounter generates records that frequently remain siloed within the originating institution or lost in physical form. When a patient later presents in an emergency—for example, unconscious after a road-traffic accident and brought to a hospital by a stranger—the receiving clinician often lacks reliable, rapid access to known drug allergies, current medications, chronic conditions, prior diagnoses, and relevant treatment history. The resulting information deficit can contribute to adverse drug events, delayed diagnosis, inappropriate triage, and suboptimal therapeutic decisions.

Patients with chronic diseases are particularly exposed. They typically receive care from multiple providers over years; medication lists evolve; allergy information may be incompletely recorded; laboratory trends reside in different systems. Paper prescriptions remain common in many settings, and even when electronic records exist, cross-institutional retrieval under time pressure is rarely seamless. In rural and low-connectivity regions the problem is compounded by intermittent network availability and limited integration with formal emergency services.

Existing electronic health record (EHR) systems improve documentation quality and availability within single institutions. Health information exchange (HIE) platforms and national initiatives such as India's Ayushman Bharat Digital Mission (ABDM) aim for interoperability through consent managers and HL7 FHIR-based exchange [1, 2]. Personal health record (PHR) applications give patients greater control over their data. Emergency medical identification solutions (QR tags, medical alert jewellery) provide limited static information. Large language model (LLM) assistants and multi-agent prototypes have demonstrated potential for clinical workflow support [10–13]. Nevertheless, no single system simultaneously delivers (a) patient-controlled ingestion of heterogeneous documents with provenance-preserving extraction, (b) multi-agent coordination under a non-overridable deterministic safety layer, (c) consent-governed emergency retrieval with minimum-necessary disclosure and short-lived tokens, and (d) offline-tolerant coordination with registered rural responders, all designed for the Indian regulatory and connectivity context.

CuraTrack addresses this intersection. It is conceived as a patient-centric healthcare information and coordination platform. Patients (or authorised caregivers) upload medical reports, prescriptions, diagnoses, and laboratory documents. An extraction pipeline converts unstructured content into structured fields accompanied by confidence scores, source references, and verification status. Specialised AI agents perform defined tasks—ingestion, structuring, medication monitoring, risk-signal detection, emergency coordination, and clinician summarisation—while communicating only through an orchestrator via schema-validated messages. A deterministic Safety and Policy Layer evaluates every safety-critical action independently of any LLM recommendation. Emergency access is mediated by a protected QR health identifier that references a short-lived access token rather than embedding the full medical record. Rural responder notification uses minimal alerts over SMS or application channels; sensitive clinical data travel only over authenticated, protected channels. Offline operation queues events for later synchronisation with conflict detection.

Throughout this paper we maintain strict distinctions:

- The proposed architecture and design rationale.
- Features that may be realised in a concrete prototype.
- Features that have been or will be evaluated through controlled experiments on synthetic data.
- Features that remain future work.

We do not claim clinical effectiveness, reduced mortality, improved diagnostic accuracy, or successful real-world deployment. The contribution is architectural, methodological, and evaluative: a coherent multi-agent design with measurable agent responsibilities, a fully specified non-LLM safety engine, a threat model and mitigation catalogue aligned with the DPDP Act 2023 and ABDM principles, a relational data model, and a reproducible evaluation protocol.

The remainder of the paper is organised as follows. Section II defines the background and central research problem. Section III reviews related work and identifies the research gap. Section IV states system requirements. Section V presents the overall architecture. Section VI details the multi-agent methodology. Section VII describes medical data extraction and structuring. Section VIII develops the privacy, security, and threat model. Section IX specifies the deterministic safety mechanism. Section X

covers emergency doctor coordination and the rural network. Section XI outlines implementation methodology and the data model. Section XII presents the experimental evaluation plan. Section XIII discusses results and discussion (evaluation plan). Section XIV provides comparative analysis. Section XV addresses limitations and ethical considerations. Section XVI outlines future work. Section XVII concludes. References and appendices follow.

2 Background and Problem Definition

2.1 The Fragmentation Problem in Detail

Healthcare delivery is inherently distributed. A single patient may interact with primary-care clinics, specialty outpatient departments, inpatient wards, diagnostic laboratories, imaging centres, pharmacies, and emergency departments, often across both public and private sectors. Each interaction generates documents—discharge summaries, prescription slips, laboratory reports, imaging reports, referral letters—that are stored according to the local institution's practices. Interoperability standards exist, yet adoption remains uneven. Paper-based records continue to circulate. Patients themselves frequently hold incomplete collections of physical or digital copies. When an emergency arises and the patient cannot communicate, the receiving clinician is left to reconstruct history from whatever fragments are available, from accompanying persons, or from institutional systems that may not contain prior encounters from other facilities.

The clinical consequences are well documented in the broader literature on adverse drug events, incomplete allergy histories, and medication reconciliation failures. The problem is not merely inconvenience; it is a safety hazard. For chronic-disease patients the longitudinal record is essential for continuity; for acute emergencies the critical subset (allergies, active medications, major chronic conditions, emergency contacts) must be available within minutes.

In the Indian context the challenge is amplified by the coexistence of highly digitised tertiary hospitals, small private clinics that still rely on paper, diagnostic chains with their own portals, and a large rural population served by primary health centres with intermittent connectivity. National programmes such as ABDM are progressively addressing interoperability, yet patient-controlled consolidation of documents that originate outside any single institutional system remains a practical necessity.

2.2 Central Research Question and Supporting Questions

The central research question investigated by this work is:

How can a secure, interoperable, and multi-agent healthcare coordination system provide authorized clinicians with accurate, relevant patient medical information during routine care and emergencies while preserving privacy and ensuring that safety-critical actions do not depend solely on large language models?

Supporting research questions are:

1. How can structured medical information be extracted reliably from heterogeneous documents (PDF, images, scanned prescriptions, laboratory reports) while preserving provenance, attaching confidence scores, and explicitly marking missing or ambiguous fields?

2. How can consent-based, least-privilege sharing of medical records be enforced for both routine clinical access and emergency legitimate-use scenarios, including revocation and audit?

3. How can specialised AI agents collaborate through structured, schema-validated messages under an orchestrator without uncontrolled agent-to-agent communication, silent invention of clinical facts, or untraceable decision paths?

4. How can deterministic, non-LLM safety checks and mandatory escalation conditions be implemented so that they cannot be overridden by any agent recommendation?

5. How can registered doctors and responders operating in rural or intermittent-connectivity settings be notified and coordinated without transmitting full medical records over SMS or similarly unprotected channels?

6. What metrics, experimental designs, and protocols adequately evaluate information retrieval accuracy, system reliability, security properties, latency, offline behaviour, and usability on synthetic or anonymised data?

3 Related Work

3.1 Electronic Health Records and Health Information Exchange

EHR systems have improved documentation quality and availability within single institutions. Health information exchange platforms aim to move records across organisational boundaries. In India, the Ayushman Bharat Digital Mission has established a national digital health ecosystem based on ABHA (Ayushman Bharat Health Account) identifiers, Health Facility and Professional Registries, consent managers, and HL7 FHIR R4 profiles for clinical document exchange [1–3]. The architecture is deliberately federated: data remain close to the point of generation, and exchange occurs only after patient consent or under defined legitimate uses. Personal health record applications complement institutional systems by giving patients a consolidated view. Nevertheless, emergency retrieval under time pressure, offline operation, and integration with informal or rural responders remain incompletely solved in many deployments.

The Health Information Exchange and Consent Manager (HIECM) gateway and the Unified Health Interface (UHI) provide standards-based protocols, yet the practical reality for many patients is still a collection of paper slips and institution-specific portals. CuraTrack is designed to operate as a patient-controlled layer that can later interoperate with ABDM rather than as a replacement for institutional systems.

3.2 Clinical Information Extraction Using NLP and OCR

Unstructured clinical text and scanned documents constitute a large fraction of the medical record. Information extraction (IE) research has progressed from rule-based systems (MetaMap, cTAKES, MedEx) through statistical and encoder-based models (ClinicalBERT and variants) to large language model pipelines [6–9]. Contemporary approaches emphasise schema-constrained generation, confidence estimation, assertion detection (negation, uncertainty), temporal resolution, and human verification. Performance on named-entity recognition and relation extraction has improved substantially, yet residual error rates, domain shift, and hallucination risk require that extracted fields carry provenance and verification status and that conflicting information is flagged rather than silently resolved. CuraTrack adopts this discipline: the Medical Record Structuring Agent never invents missing medical facts and never autonomously reconciles conflicting prescriptions or allergy lists.

OCR error rates on handwritten Indian prescriptions and mixed-language documents remain a practical challenge. Confidence propagation from the OCR lattice into field-level scores is therefore treated as a first-class design requirement rather than an afterthought.

3.3 Multi-Agent AI Systems in Healthcare

Recent surveys and systems demonstrate that orchestrated multi-agent designs can sustain higher accuracy under clinical-scale workloads than single-agent LLMs, enable role specialisation, support safety gates, and produce audit-ready traces [10–15]. Applications include triage, discharge readiness assessment, EHR natural-language querying, crisis clinical decision support under incomplete information, and prescription decision support. Key design principles that emerge are explicit agent roles, structured hand-offs, shared state management, tool use grounded in EHR or guidelines, and mandatory safety or critique stages. CuraTrack builds on these principles while adding a non-LLM deterministic Safety and Policy Layer that evaluates every side-effecting action and by restricting inter-agent communication to orchestrator-mediated, schema-validated messages.

3.4 LLM Safety, Human-in-the-Loop, and Deterministic Safeguards

LLM outputs are probabilistic and can hallucinate clinical facts, invent dosages, or resolve conflicts incorrectly. Best practice therefore requires human confirmation for prescriptions, explicit marking of unknown fields, and independent enforcement of

authorisation and emergency rules. CuraTrack elevates these practices to a first-class architectural component: the Safety and Policy Layer is implemented as pure deterministic functions of authenticated identity, consent state, request type, and current record state. No LLM participates in the evaluation of safety rules.

3.5 Consent-Based Access Control and Emergency Medical Information Systems

The DPDP Act 2023 requires free, specific, informed, and unambiguous consent for processing of personal data, with legitimate-use exceptions that include medical emergencies involving a threat to life or immediate threat to health [4, 5]. ABDM operationalises consent through consent managers and purpose-limited data exchange. Traditional emergency medical identification solutions (QR codes, medical alert jewellery, implanted identifiers) typically embed limited static data and lack dynamic consent, audit, and revocation. CuraTrack uses a protected QR that references a short-lived access token; the full record is never stored in the QR payload. Access is logged, minimum-necessary disclosure is enforced, and post-emergency review is supported.

3.6 Rural Telehealth and Low-Connectivity Architectures

Rural and resource-constrained settings require designs that tolerate intermittent connectivity, delayed synchronisation, and unreliable delivery acknowledgements. Offline-first mobile applications, local encrypted stores, and conflict-resolution protocols are established techniques. CuraTrack incorporates an offline synchronisation service that queues events, preserves durability, and applies clinical-priority or last-writer-wins rules upon reconnection, while ensuring that sensitive clinical payloads never travel in clear text over SMS.

3.7 Research Gap

While each of the above research streams has produced valuable results, their integration under a single privacy-preserving, multi-agent, deterministically safeguarded architecture tailored to the Indian regulatory and connectivity environment remains incomplete. CuraTrack occupies this gap by providing an explicit multi-agent design with measurable agent responsibilities, a fully specified non-LLM safety engine, a realistic emergency access model, a threat model and mitigation set, and an evaluation protocol that can be executed on synthetic data without requiring real patient records.

4 System Requirements

4.1 Functional Requirements

- Patients or authorised caregivers can upload medical documents in common formats (PDF, JPEG/PNG images of prescriptions or reports, structured text).
- The system extracts structured fields (medications with dosage and frequency, allergies and reactions, diagnoses and chronic conditions, laboratory results, procedures, document date and issuing provider) together with confidence scores and provenance.
- Ambiguous, low-confidence, or conflicting fields are flagged and presented for human verification; missing required clinical information is explicitly marked “unknown”.
- Clinicians can retrieve a source-linked, purpose-limited summary of relevant history under valid consent or emergency legitimate-use rules.
- Doctors can dictate prescriptions; speech recognition produces text; the system structures the text into fields, highlights uncertainty, and requires explicit clinician confirmation before the prescription becomes an active medication schedule.
- In emergencies, authorised responders receive minimal alerts and, after authentication, access only the minimum necessary clinical subset.

- Offline operation on a patient or clinician device queues events for later synchronisation; conflicts are detected and resolved according to defined policy.
- Every access event, agent decision, and safety-rule evaluation is recorded in an append-only audit log.

4.2 Non-Functional Requirements

- Privacy by design: data minimisation, encryption at rest and in transit, short-lived tokens, purpose limitation, and support for consent revocation.
- Deterministic safety: critical rules execute independently of any LLM and cannot be overridden by agent recommendations.
- Measurable latency targets for emergency retrieval under controlled laboratory conditions (to be established experimentally).
- Auditability and non-repudiation of access and decision events.
- Resilience to intermittent connectivity without silent data loss.
- Role-based and attribute-based access control with least privilege.
- Resistance to prompt injection via uploaded documents and to sensitive-data leakage through model prompts or logs.

4.3 Stakeholder Analysis

Primary stakeholders include patients (and authorised caregivers), treating clinicians, emergency physicians, registered rural responders, system administrators, and, in a future ABDM-integrated scenario, Health Information Providers and Users. Secondary stakeholders include auditors, ethics review boards, and national digital-health programme administrators. Requirements were derived from the clinical safety problem, the regulatory constraints of the DPDP Act, and the connectivity realities of rural India.

5 Proposed Architecture

CuraTrack is organised as a modular, service-oriented system. The principal logical layers are:

1. **Presentation Layer**: web clients (React or Next.js) and mobile clients (React Native) for patients, clinicians, and responders. Interfaces support document upload, consent management, summary viewing, prescription confirmation, and emergency workflows.
2. **API Gateway and Authentication**: JWT-based session management, multi-factor authentication where appropriate, role-based access control, rate limiting, and request validation.
3. **Orchestrator and Multi-Agent Runtime**: task queue, structured message bus, agent lifecycle management, schema registry, and task-graph execution. Agents never communicate directly with one another.
4. **Domain Services**: document storage and retrieval, structured longitudinal record store, consent service, emergency event service, notification service (SMS and push), and audit-log service.
5. **AI Services**: OCR and PDF parsing (Python/FastAPI), LLM-assisted structuring (local models via Ollama or equivalent where implemented in a prototype), speech-to-text for voice prescriptions.
6. **Safety and Policy Layer**: pure deterministic rule engine, independent of model outputs, invoked on every side-effecting request.
7. **Data Layer**: PostgreSQL for relational entities and metadata, encrypted object storage for original documents, append-only audit log (optionally with cryptographic chaining).

8. **Offline Synchronisation Service**: local encrypted store on device, durable event queue, conflict detection and resolution on reconnection.

The final technology stack selected for any concrete prototype implementation must be recorded explicitly in accompanying project documentation. The technologies listed above are design options; their presence in this paper does not constitute a claim that every component has been implemented.

5.1 Overall System Architecture (Conceptual Description)

Patient upload flows through the Data Ingestion Agent to the Medical Record Structuring Agent and thence into the structured store under Safety and Policy Layer oversight. Clinician queries are authorised by the consent service, summarised by the Doctor Copilot Agent, validated by the Safety Layer, and returned with provenance. Emergency paths begin with an authenticated SOS or QR-mediated request, trigger the Emergency Coordination Agent under deterministic rules, issue short-lived tokens, and enforce minimum-necessary disclosure. Rural responder notification uses minimal alerts; clinical data move only after authentication over protected channels. Offline devices operate against local stores and later synchronise with conflict detection.

5.2 Multi-Agent Interaction Model

Agents exchange only structured, schema-validated messages mediated by the orchestrator. Each message carries a type, correlation identifier, timestamp, sender agent identifier, and payload conforming to a published schema. The orchestrator maintains a task graph, enforces ordering constraints (e.g., structuring must complete before risk-signal evaluation on the same document set), records intermediate state, and guarantees that Safety and Policy Layer evaluation occurs after any agent recommendation and before any side-effecting action (prescription activation, data disclosure, notification dispatch containing clinical content). Direct agent-to-agent channels are prohibited by design.

5.3 Key Sequence Flows

- **Document Ingestion Sequence**: client upload → authentication and virus/malware scan → immutable storage of original with cryptographic hash → Data Ingestion Agent → OCR/text extraction → Medical Record Structuring Agent (field extraction, confidence, provenance, conflict detection) → provisional structured record → optional human verification queue → Safety Layer validation → committed longitudinal profile update → audit.
- **Voice Prescription Workflow**: clinician initiates dictation → speech-to-text → structuring into medication fields → uncertainty and ambiguity highlighting → clinician confirmation user interface → only after explicit confirmation does the Safety Layer permit activation of a medication schedule → audit.
- **Emergency Access Sequence**: QR presentation or SOS → clinician or responder authentication → legitimate-use or consent evaluation by Safety Layer → short-lived token issuance → Doctor Copilot preparation of minimum-necessary summary → disclosure → full audit trail → post-event patient/guardian notification when contact is re-established.
- **Consent and Authorisation Workflow**: patient creates or updates ConsentGrant (purpose, scope, expiry, authorised parties) → Consent service stores and indexes → every subsequent access request is evaluated against active grants → revocation takes immediate effect for new requests → residual offline copies are subject to secure deletion protocols upon next synchronisation.
- **Offline Synchronisation Workflow**: local write to encrypted store → durable queue entry → network restoration → upload of queued events → server-side conflict detection (timestamp, clinical priority, or explicit merge rules) → resolution audit → acknowledgment to device.
- **Rural Responder Coordination**: emergency event capture → deterministic rule evaluation → query of registered responders by location, specialty, availability → minimal alert dispatch (event identifier, approximate location, urgency code) → acknowledgement or timeout → escalation → authenticated clinical-data channel.

6 Multi-Agent Coordination Methodology

6.1 Design Principles

The multi-agent design is guided by four principles: (1) specialisation—each agent has a narrow, measurable responsibility; (2) structured communication—messages conform to schemas and travel only through the orchestrator; (3) fail-safe defaults—on uncertainty or failure the system denies side effects and escalates to humans; (4) independent safety—the Safety and Policy Layer is not an agent and cannot be influenced by agent outputs.

6.2 Agent Catalogue and Contracts

1. **Data Ingestion Agent**

    - *Inputs*: document binary or reference, patient identifier (synthetic), upload metadata, authentication context.
    - *Outputs*: document identifier, cryptographic hash of original, extracted raw text or OCR lattice, format and language metadata, success/failure status.
    - *Boundaries*: does not interpret clinical meaning; does not invent text; rejects malformed or malicious payloads after scanning.
    - *Failure handling*: virus detection or unreadable format produces a permanent failure record and user notification; transient OCR failures may be retried under orchestrator control.

2. **Medical Record Structuring Agent**

    - *Inputs*: raw text or OCR output, document identifier, existing longitudinal profile (for conflict detection).
    - *Outputs*: set of structured field assertions, each carrying field name, value, confidence, source span or page, extraction timestamp, verification status (unverified / patient-confirmed / clinician-verified), and conflict flags.
    - *Boundaries*: never invents missing medical facts; never silently chooses among conflicting values; never activates prescriptions.
    - *Failure handling*: low-confidence or conflicting extractions sets are placed in a human verification queue; the agent itself reports partial success with explicit uncertainty markers.

3. **Medication Monitoring Agent**

    - *Inputs*: confirmed (clinician-verified) prescription records only, patient schedule preferences.
    - *Outputs*: adherence reminder events (non-clinical), schedule status summaries.
    - *Boundaries*: never alters dosages, frequencies, or medication identity; never generates clinical advice.
    - *Failure handling*: missing confirmed prescription simply yields an empty schedule; no speculative filling of gaps.

4. **Clinical Risk Signal Agent**

    - *Inputs*: structured longitudinal profile, clinician-authored pattern definitions (e.g., known allergen present in active medication list).
    - *Outputs*: review flags with pattern identifier, matched evidence, and severity category.
    - *Boundaries*: does not diagnose; does not recommend treatment; does not suppress or elevate flags autonomously beyond the predefined patterns.
    - *Failure handling*: pattern evaluation errors produce a system-level alert for operator review; clinical care continues without the flag rather than with an invented flag.

5. **Emergency Coordination Agent**

- *Inputs*: authenticated emergency event, location (if available), patient identifier, current consent and legitimate-use state.
- *Outputs*: ordered list of candidate responders, dispatch instructions for minimal alerts, escalation decisions, timeline records.
- *Boundaries*: does not transmit clinical content in clear-text alerts; does not override Safety Layer denial of disclosure.
- *Failure handling*: absence of available responders triggers predefined escalation to official emergency services or broader geographic search; timeouts are explicit and audited.

6. **Doctor Copilot Agent**

   - *Inputs*: authenticated clinician identity, purpose of access, longitudinal profile (already authorised by Safety Layer), requested scope.
   - *Outputs*: concise, source-linked summary; every clinical statement carries provenance to one or more source documents or structured records.
   - *Boundaries*: does not invent facts; does not omit the "unknown" marker when critical fields are missing; does not expand scope beyond the authorised purpose.
   - *Failure handling*: inability to produce a summary within latency bounds returns a partial or "insufficient data" response rather than a fabricated narrative.

7. **Safety and Policy Layer** (not an agent)

   - *Inputs*: request type, authenticated caller, consent state, current record state, agent recommendations (if any).
   - *Outputs*: Allow, Deny (with reason), or AllowAndEscalate.
   - *Boundaries*: pure function; no learning; no LLM; no side effects other than the decision and the mandatory audit event.

6.3 Orchestration Protocol and Error Handling

Tasks are submitted as typed JSON objects conforming to a versioned schema registry. The orchestrator validates schema, enforces agent ordering and data dependencies, records intermediate state in a durable task store, and guarantees the Safety Layer is invoked at every decision point that can produce a side effect. Recoverable errors (transient network or OCR failures) trigger bounded retries with exponential backoff and jitter. Unrecoverable errors (schema violation, authentication failure, Safety Layer denial, unrecoverable agent crash) produce an explicit failure record, notify the responsible human role, and leave the system in a safe state: no partial clinical disclosure, no activation of unverified prescriptions, no irreversible external notifications containing clinical content.

6.4 Message Schema Example

A typical structured message from the Structuring Agent to the orchestrator contains fields such as `task_id`, `agent_id`, `document_id`, `fields[]` (each with name, value, confidence, source_span, status), `conflicts[]`, and `status`. The orchestrator validates the schema before any downstream agent or Safety Layer evaluation proceeds.

7 Medical Data Extraction and Structuring

7.1 Pipeline Stages

1. **Reception and Immutable Storage**: the original document is stored with a cryptographic hash (SHA-256 or stronger). The hash becomes part of the provenance record.

2. **Preprocessing**: format detection, image deskewing and enhancement where needed, language identification.

3. **OCR / Text Extraction**: character- and word-level lattices are retained when available so that confidence can be propagated.

4. **Field Extraction**: rule-based patterns, encoder models, or constrained LLM generation map text to the target schema. Target fields include patient identifier (synthetic), medication name, dosage, frequency, route, allergies and recorded reactions, diagnoses and chronic conditions, laboratory results with units and reference ranges where present, previous procedures, document date, and issuing provider.

5. **Confidence and Provenance Attachment**: every field assertion receives a confidence score (model probability, rule match strength, or ensemble agreement), a source document identifier, a source span or page reference, and an extraction timestamp.

6. **Conflict Detection**: newly extracted values are compared with the existing longitudinal profile. Conflicting high-severity items (especially allergies and active medications) are flagged rather than reconciled.

7. **Verification Queue**: low-confidence or conflicting items enter a human verification workflow accessible to the patient (for non-clinical corrections) or to authorised clinicians.

8. **Commitment**: only after Safety Layer approval does the structured update become part of the authoritative longitudinal profile.

7.2 Handling of Uncertainty and Error

Incorrect OCR, outdated records, conflicting prescriptions, and incomplete allergy information are first-class concerns. The system never allows an LLM to independently invent missing medical facts or to silently resolve conflicts. Missing required clinical information is explicitly marked "unknown" in any summary presented to a clinician. Confidence thresholds are configurable; values below threshold cannot become confirmed prescriptions or high-confidence risk signals without human confirmation.

7.3 Voice-Based Digital Prescription

A doctor dictates a prescription; speech recognition converts it into text. The system then structures the prescription into fields, validates required information, highlights uncertainty (homophones, dosage ambiguity, language differences), and presents it to the prescribing clinician for confirmation. Only after clinician confirmation does the prescription become an active medication schedule. Speech-recognition errors, medication-name ambiguity, dosage errors, and language differences are treated as uncertainty that blocks automatic activation.

8 Privacy and Security Design

8.1 Threat Model

Adversaries considered include external network attackers, credential thieves, compromised or malicious agents, insider threats with elevated privileges, prompt-injection adversaries who craft malicious document content, and physical thieves of offline devices. Assets of value are patient identifiers, clinical facts (especially allergies and medications), access tokens, consent state, and the integrity of the audit log.

8.2 Threat Table

Table 1: Threat Model Summary for CuraTrack

Threat	Attack Scenario	Potential Impact	Mitigation	Residual Risk
Unauthorised access	Stolen credentials, session hijacking, QR misuse	Exposure of clinical record	Short-lived tokens, MFA, RBAC, rate limiting, token binding	Compromised endpoint device
Prompt injection	Malicious text inside uploaded document	Agent misbehaviour or data leakage	Input sanitisation, schema-constrained extraction, Safety Layer	Novel injection patterns
Log leakage	Verbose model traces or debug logs containing PHI	Unintended disclosure	Redaction pipelines, separate log channels, retention limits	Misconfiguration
Insider threat	Privileged user abuse or compromised administrator	Targeted or bulk disclosure	Least privilege, dual control for sensitive operations, continuous audit	Trusted insider with physical access
Offline device theft	Lost or stolen phone with local encrypted store	Local record exposure	Strong device encryption, remote wipe capability, short local retention	Window before wipe executes
SMS interception	Capture of alert content	Metadata and location leakage	Minimal alert payload; clinical data only on authenticated channel	Inference from metadata patterns
Token replay	Reuse of captured access token	Unauthorised disclosure	Short lifetime, single-use or limited-use tokens, audience restriction	Very short window if lifetime is small
Consent bypass	Ignoring revocation or scope	Over-disclosure	Centralised consent evaluation on every request; immediate revocation effect	Stale offline caches (mitigated by sync policy)

8.3 Controls in Detail

- **Encryption**: TLS 1.3 for data in transit; AES-256 (or equivalent) for data at rest, with key management separated from application servers.
- **Authentication and Session Management**: strong authentication, short session lifetimes, refresh-token rotation, device binding where feasible.
- **Authorisation**: role-based and attribute-based access control; every request carries authenticated identity and is evaluated against consent grants or legitimate-use rules.
- **Consent**: free, specific, informed, unambiguous grants with purpose, scope, expiry, and revocation. Revocation is effective for

all subsequent requests.

- **Short-lived Access Tokens**: emergency QR flows issue tokens with lifetimes measured in minutes, bound to the requesting clinician identity and purpose.
- **Audit Trails**: append-only, preferably cryptographically chained logs of authentication events, consent changes, access events (who, what fields, when, under what purpose), agent task outcomes, and Safety Layer decisions.
- **Data Minimisation**: emergency summaries contain only allergies, active medications, critical chronic conditions, and emergency contacts unless broader consent exists.
- **Secure Agent Communication**: agents speak only to the orchestrator; messages are authenticated and schema-validated; free-form multi-agent chat is prohibited.
- **Prompt-Injection Defences**: document content is never concatenated into unconstrained system prompts; extraction uses constrained decoding or post-generation schema validation; Safety Layer remains independent.
- **API Security**: rate limiting, input validation, output encoding, and regular security testing.
- **Backup and Recovery**: encrypted backups with tested restoration procedures; recovery time and point objectives defined for the prototype environment.
- **Data Retention and Deletion**: policies aligned with purpose limitation; support for patient-requested deletion subject to legal retention requirements.

A centralised database simplifies retrieval and consistency but creates a high-value target. A hybrid or federated model (central index of metadata and consent, encrypted personal or facility stores for clinical content) is retained as a future architectural option consistent with ABDM's federated principles. CuraTrack does not claim current legal compliance, ABDM certification, or production security certification; the design aims to be compatible with those frameworks.

9 Deterministic Safety Mechanism

9.1 Rationale

Safety-critical decisions—whether to disclose clinical data, whether to activate a prescription, whether to escalate an emergency—must not depend solely on the probabilistic outputs of large language models. The Safety and Policy Layer is therefore implemented as a set of pure, deterministic functions. It receives the request, the authenticated identity, the current consent and record state, and any agent recommendation, and returns Allow, Deny, or AllowAndEscalate. The decision is audited before any side effect occurs.

9.2 Selected Safety Rules

- **R1 – Unauthorised Request**. Trigger: caller lacks required role or valid consent/legitimate-use flag for the requested purpose and scope. Required action: Deny and write audit event AUTH_FAIL or CONSENT_FAIL. Prohibited action: return any clinical field. Failure handling: safe deny; no partial data.
- **R2 – Unverified Prescription Activation**. Trigger: any required field (medication identity, dose, frequency) has confidence below threshold or is marked uncertain/ambiguous. Required action: Deny activation; present confirmation UI to prescribing clinician. Prohibited action: silently activate. Audit: RX_UNCERTAIN. Failure handling: prescription remains provisional.
- **R3 – Conflicting Allergy or Medication Information**. Trigger: two or more sources disagree on a high-severity allergy or on an active high-risk medication. Required action: flag both (or all) values and present to clinician; do not choose. Prohibited action: silent resolution by majority or by model preference. Audit: CONFLICT_FLAGGED.

- **R4 – Authenticated SOS**. Trigger: validated, authenticated SOS or emergency event. Required action: invoke Emergency Coordination Agent workflow independently of any concurrent LLM recommendation. Prohibited action: allow an LLM to suppress or delay the emergency workflow. Audit: SOS_ACCEPTED.
- **R5 – Missing Critical Field**. Trigger: allergy list or active medication list is empty or explicitly marked unknown. Required action: emergency summary must display the explicit "unknown" marker for that section. Prohibited action: omit the section or invent a value. Audit: UNKNOWN_FIELD_PRESENTED.
- **R6 – Scope Exceedance**. Trigger: requested disclosure exceeds the purpose or field scope of the active consent or legitimate-use rule. Required action: Deny excess fields; allow only the intersection. Audit: SCOPE_TRIMMED or SCOPE_DENIED.
- **R7 – Rate-Limit and Bulk Access**. Trigger: abnormal volume of access requests from a single identity or token. Required action: throttle or deny and raise security alert. Audit: RATE_LIMIT_TRIGGERED.
- **R8 – Post-Emergency Review Flag**. Trigger: successful emergency disclosure. Required action: set mandatory review flag for subsequent human audit. Audit: EMERGENCY_REVIEW_REQUIRED.

9.3 Pseudocode of the Safety Engine

Listing 1: Simplified Safety and Policy Engine

```
def evaluate(request, context):
    # Authentication gate
    if not is_authenticated(request.caller):
        write_audit("AUTH_FAIL", request)
        return Decision.DENY("Authentication required")

    # Consent / legitimate-use gate for disclosure
    if request.type in DISCLOSURE_TYPES:
        if not has_valid_consent_or_emergency(request, context):
            write_audit("CONSENT_FAIL", request)
            return Decision.DENY("No valid consent or emergency basis")
        # Minimum-necessary trimming
        allowed_fields = intersect(request.requested_fields,
                                   permitted_fields(request, context))
        if not allowed_fields:
            write_audit("SCOPE_DENIED", request)
            return Decision.DENY("No permitted fields")
        request.requested_fields = allowed_fields

    # Prescription activation gate
    if request.type == "ACTIVATE_RX":
        for field in required_fields(request.prescription):
            if field.confidence < CONFIDENCE_THRESHOLD \
               or field.status in ("uncertain", "ambiguous"):
                write_audit("RX_UNCERTAIN", request)
                return Decision.DENY("Clinician confirmation required")

    # Conflict presentation gate
    if request.type == "COMMIT_STRUCTURED" and has_high_severity_conflicts(request):
        write_audit("CONFLICT_FLAGGED", request)
        # Allow commit of flagged record, but surface conflicts
        return Decision.ALLOW_WITH_FLAGS(request.conflicts)

    # Emergency SOS gate (independent of LLM)
    if request.type == "EMERGENCY_SOS" and request.authenticated:
        write_audit("SOS_ACCEPTED", request)
```

```
        return Decision.ALLOW_AND_ESCALATE("EmergencyCoordinationAgent")

    # Missing critical field presentation
    if request.type == "EMERGENCY_SUMMARY":
        ensure_unknown_markers(request.summary, context.profile)
        write_audit("UNKNOWN_FIELD_PRESENTED", request)

    # Rate limiting
    if exceeds_rate_limit(request.caller, context):
        write_audit("RATE_LIMIT_TRIGGERED", request)
        return Decision.DENY("Rate limit exceeded")

    return Decision.ALLOW()
```

For every rule the implementation records the trigger condition, the required action, the prohibited action, the audit event identifier, and the failure-handling behaviour. Emergency triage support is cleanly separated from medical diagnosis or treatment recommendation; the system never claims diagnostic competence.

10 Emergency Doctor Coordination

10.1 Realistic Scenario

Consider a patient who is unconscious after a road-traffic accident and is brought to a hospital by a stranger. The authorised clinician needs rapid access to known allergies, current medications, important chronic conditions, relevant previous medical history, and emergency contacts. The system must retrieve this information securely without assuming that anyone who scans a QR code automatically receives unrestricted access.

10.2 Secure QR Health Identifier

The QR code encodes a protected reference (for example, a patient pseudonym plus a cryptographic challenge or a one-time locator) that can be resolved only by an authenticated, authorised client. It does not contain the medical record itself. Upon successful authentication and Safety Layer approval, a short-lived access token is issued. The token is bound to the clinician identity, the purpose (emergency), and a narrow field scope. Token lifetime is measured in minutes. All subsequent requests present the token and are re-evaluated.

10.3 End-to-End Emergency Workflow

1. Capture of the reported emergency and, when available, location.
2. Application of predefined deterministic emergency rules (R4).
3. Identification of nearby registered and available healthcare responders (or the receiving hospital clinician).
4. Dispatch of a minimal alert through SMS or application notification (event identifier, approximate location, urgency code). Clinical content is never placed in the clear-text alert.
5. Responder acknowledgement or decline within a configurable timeout.
6. Escalation to additional responders or official emergency services if required.
7. After authentication, sharing of the minimum-necessary clinical subset through an authorised, protected channel.
8. Recording of the full response timeline and outcome.
9. Post-emergency review and patient/guardian notification when contact is re-established.

10.4 Offline and Intermittent Connectivity

Local event queues on devices ensure that emergency declarations and acknowledgements are not lost when connectivity is absent. Upon reconnection, events are uploaded idempotently. Delivery acknowledgements over SMS are treated as best-effort; absence of an acknowledgement does not by itself prove non-receipt. Conflict detection on synchronisation prevents divergent emergency states from remaining unresolved.

11 Implementation Methodology and Data Model

11.1 Engineering Stages

1. Requirements and stakeholder analysis (patients, clinicians, rural responders, administrators).
2. Medical data schema design aligned with the fields listed earlier and with future FHIR mapping.
3. Document ingestion and extraction pipeline.
4. Patient longitudinal record creation and update logic.
5. Agent orchestration runtime and schema registry.
6. Deterministic Safety and Policy Layer implementation and unit tests.
7. Authorisation and consent management service.
8. Emergency notification and responder coordination workflow.
9. Offline synchronisation service and conflict resolution.
10. Security testing, audit-log verification, and evaluation harness on synthetic data.

Where implementation details are not supplied by an actual prototype, they are identified as proposed designs.

11.2 Relational Data Model (Core Entities)

- **Patient**: synthetic identifier, limited demographics under consent, emergency contact references.
- **HealthcareProvider** and **HealthcareFacility**: registration identifiers, specialty, availability status.
- **MedicalDocument**: document identifier, cryptographic hash, source, date, language, verification status, storage locator.
- **MedicationRecord**, **AllergyRecord**, **Diagnosis**, **LabResult**, **Procedure**: each with value, confidence, provenance (document and span), verification status, timestamps.
- **ConsentGrant**: grant identifier, patient, purpose, scope (field set or document set), authorised parties or roles, issued and expiry timestamps, revocation timestamp (nullable).
- **AccessEvent**: event identifier, caller, purpose, fields disclosed, token identifier, timestamp, outcome.
- **EmergencyEvent**: event identifier, patient, location, triggering party, status, timeline.
- **Responder** and **ResponderAcknowledgement**: registration, location, specialty, acknowledgement status and timestamp.
- **AgentTask**: task identifier, agent type, input and output references, status, error codes, timestamps.
- **Prescription**: provisional or active status; activation permitted only after clinician confirmation and Safety Layer approval.

- **SyncEvent**: device identifier, event payload hash, conflict resolution outcome, timestamps.

Primary keys, foreign keys, creation and update timestamps, and soft-delete or retention flags are mandatory. Raw medical content, passwords, and unrestricted personal identifiers never appear inside QR codes, SMS bodies, or unstructured logs. All examples in documentation and evaluation use synthetic patient identifiers.

11.3 Entity-Relationship Overview

The Patient entity is the root of the clinical graph. MedicalDocuments are linked to Patient and produce zero or more structured records (Medication, Allergy, Diagnosis, Lab, Procedure). ConsentGrant and AccessEvent reference Patient and the acting Provider. EmergencyEvent references Patient and may generate ResponderAcknowledgement records. AgentTask records provide an audit trail of every multi-agent execution. The design intentionally keeps the clinical content and the access-control metadata in the same relational store for transactional consistency while allowing future separation into a hybrid architecture.

12 Experimental Methodology

All experiments use synthetic data, public de-identified datasets, or properly anonymised data. Real patient data are not used in the demonstration environment.

12.1 Document Processing Metrics

- Field extraction precision, recall, and F1-score per field type (medication, allergy, diagnosis, laboratory value, etc.).
- OCR character error rate and word error rate on controlled synthetic document images.
- Rate of correct identification of missing or ambiguous fields (i.e., the system marks "unknown" when the ground-truth field is absent).

12.2 Information Retrieval Metrics

- Accuracy of retrieving the relevant critical subset (allergies, active medications, major conditions).
- Completeness of critical-field retrieval under the emergency minimisation policy.
- Retrieval latency (median and 95th percentile) under controlled load.

12.3 Multi-Agent Coordination Metrics

- Successful task-completion rate for defined workflows.
- Structured-message validation success rate.
- Agent failure detection and recovery rate.
- End-to-end workflow latency from upload to structured commit, and from emergency declaration to first authenticated disclosure.

12.4 Safety Metrics

- Fraction of deterministic rules correctly enforced on a suite of adversarial and boundary test cases.
- Unauthorised-access rejection rate (target 100 % on the test suite).
- Emergency escalation reliability in controlled scenarios.
- Rate of unverified prescriptions that are incorrectly accepted by the workflow (target 0 %).

12.5 Security Metrics

- Authorisation test coverage.
- Consent revocation effectiveness (immediate denial of subsequent requests).
- Token expiration and replay rejection tests.
- Audit-log completeness (every required event type present).
- Prompt-injection and data-leakage tests on crafted documents.

12.6 Offline Operation Metrics

- Local workflow completion rate without network.
- Queued-event persistence across device restarts.
- Synchronisation conflict handling correctness.
- Recovery success after simulated network interruption.

Metric definitions follow standard information-retrieval and classification formulae:

$$\text{Precision} = \frac{TP}{TP + FP}, \quad \text{Recall} = \frac{TP}{TP + FN}, \quad F_1 = 2 \cdot \frac{\text{Precision} \cdot \text{Recall}}{\text{Precision} + \text{Recall}}. \tag{1}$$

Results tables are prepared as templates and remain empty or marked "pending experiment" until measurements are executed. No numerical success rates, latency figures, or statistical significance claims are asserted in this paper.

13 Results and Discussion

Because controlled experiments on the full architecture have not yet been executed at the time of writing, this section presents the evaluation plan rather than measured outcomes. The architecture is hypothesised to improve the speed and reliability with which authorised clinicians can obtain critical patient history, to reduce dependence on patient memory or accompanying persons, to enforce consent and minimum-necessary disclosure, and to keep safety-critical decisions independent of LLM stochasticity. These hypotheses require empirical validation.

Assumptions that must be tested include the reliability of OCR on Indian-language and handwritten prescriptions, the accuracy of speech recognition for medication names across accents and languages, the actual availability patterns of registered rural responders, and the willingness of clinicians to confirm structured prescriptions in realistic workflows. Potential failure modes include incomplete patient uploads, stale or conflicting records that have not yet been verified, false-positive or false-negative risk signals, and institutional barriers to integration with existing hospital information systems and official emergency services. Trade-offs exist among privacy (strict minimisation), accessibility (speed of emergency retrieval), latency, and availability (offline operation). AI-generated summaries are bounded by source provenance and are never treated as definitive clinical statements. The difficulty of connecting to external hospitals and emergency services, and the human factors that influence adoption, remain open issues for future study.

14 Comparative Analysis

Table 2 provides a qualitative comparison across relevant solution categories. Evidence is drawn from the published capabilities of each category rather than from unverified claims about specific commercial products.

Table 2: Comparative Matrix of Solution Categories

Dimension	Paper-based	Standalone EHR	PHR App	HIE / ABDM	Emergency ID	Single-LLM Assistant
Record portability	Low	Medium	High	Medium–High	Low	Low
Consent management	Low	Medium	High	High	Low	Low
Emergency retrieval	Low	Medium	Medium	Medium	Medium	Low
Multi-agent collaboration	None	None	None	None	None	Limited
Deterministic safety layer	None	Partial	Low	Partial	Low	Low
Rural / offline support	Medium	Low	Medium	Low–Medium	Medium	Low
Auditability	Low	High	Medium	High	Low	Low
Standards interoperability	Low	Medium	Medium	High	Low	Low

CuraTrack is designed to strengthen the combination of consent-managed emergency retrieval, multi-agent coordination under deterministic safety, and offline-tolerant rural notification relative to the listed categories, while remaining architecturally compatible with future ABDM FHIR exchange. Any claim of empirical superiority awaits execution of the evaluation protocol.

15 Limitations and Ethical Considerations

- Incomplete patient-uploaded records remain a fundamental limitation; the system can only surface information that has been provided and successfully structured.
- OCR and speech-recognition errors introduce residual uncertainty; confidence scores and mandatory human confirmation mitigate but do not eliminate the risk.
- Unverified allergies and conflicting prescriptions must be presented as such; silent resolution is prohibited yet the clinician must still interpret the conflict.
- Risk signals can produce false positives (unnecessary review) or false negatives (missed patterns); they are review flags only.
- Model hallucinations are constrained by schema enforcement and provenance requirements but are not guaranteed to be zero.
- Unauthorised access remains a residual risk under compromised credentials or devices; continuous monitoring and short token lifetimes reduce but do not remove the window.
- Consent withdrawal must be effective immediately for online requests; residual offline copies require secure deletion protocols that themselves depend on eventual synchronisation.
- Limited connectivity can delay both synchronisation and responder reachability.
- Integration with external hospital systems and official emergency services faces institutional, technical, and governance barriers.
- Potential healthcare inequity arises if the platform is accessible primarily to digitally literate or urban patients; inclusive design and offline support are partial mitigations.
- Clinical validation under appropriate ethics and governance frameworks is a prerequisite for any real-world clinical use.

CuraTrack is a decision-support and coordination platform. It does not diagnose, prescribe, treat, or replace licensed medical professionals or statutory emergency services. All clinical responsibility remains with qualified human practitioners.

16 Future Work

Realistic future directions include:

- Standards-based registration and data exchange under ABDM, using the published FHIR R4 implementation guides for clinical documents.
- Secure integration pathways with participating healthcare facilities that choose to act as Health Information Providers or Users.
- Improved multilingual voice input and handwritten-document extraction, particularly for Indian languages and regional prescription formats.
- Stronger document verification and provenance mechanisms (digital signatures, institutional attestation).
- More robust offline operation, including selective local caching policies and conflict-resolution strategies tuned to clinical priority.
- Integration with authorised emergency services under appropriate legal and operational agreements.
- Privacy-preserving analytics on consented, aggregated, or de-identified data.
- Prospective clinical evaluation under ethics approval and governance.
- Scalability, reliability, adversarial robustness, and long-term audit integrity testing.

These items are explicitly future work and are distinguished from any current prototype capabilities.

17 Detailed Agent Interaction Protocols

17.1 Structured Message Formats

Every inter-component message is a JSON object validated against a versioned JSON Schema. Mandatory fields include `message_id` (UUID), `correlation_id`, `timestamp` (ISO-8601), `sender`, `recipient` (always the orchestrator for agents), `message_type`, and `payload`. Optional fields include `priority`, `expires_at`, and `trace_context` for distributed tracing.

17.2 Task Graph Example for Document Ingestion

A typical ingestion task graph consists of the following ordered stages:

1. VirusScanTask
2. ImmutableStoreTask
3. OCRExtractionTask
4. StructuringTask
5. ConflictDetectionTask
6. SafetyValidationTask
7. CommitTask
8. AuditTask

Each stage produces artefacts that become inputs to subsequent stages. Failure at any stage aborts the graph with a compensating action (e.g., marking the document as failed and notifying the uploader).

17.3 Failure Recovery Strategies

Transient failures (HTTP 503, temporary OCR service unavailability) are retried up to three times with exponential backoff. Permanent failures (schema violation, Safety Layer denial, malware detection) are terminal for that task instance and generate an operator alert. The system never retries a Safety Layer denial.

18 Additional Security Considerations

18.1 Key Management

Encryption keys for data at rest are managed by a dedicated key-management service. Application servers receive only short-lived data-encryption keys. Master keys are never present on application hosts. Key rotation is scheduled and audited.

18.2 Session and Token Lifecycle

Access tokens issued for emergency QR flows have a default lifetime of five minutes and are single-use for the initial disclosure request. Subsequent requests within the same emergency episode may reuse a refreshed token with a renewed short lifetime, subject to continuous Safety Layer evaluation. Refresh is denied if consent has been revoked or if the emergency episode has been closed.

18.3 Audit Log Integrity

The preferred implementation of the audit log uses a hash-chained structure: each new entry contains the cryptographic hash of the previous entry. Periodic snapshots of the chain head are written to an immutable external store. This design supports detection of log tampering.

19 Usability and Human Factors

Although formal usability studies remain future work, the design incorporates several human-factors considerations. Clinician confirmation screens for voice prescriptions highlight uncertain fields in a distinct visual style and require an explicit affirmative action (not merely dismissal of a dialog). Emergency summaries present the critical subset first (allergies, active medications, major conditions) before any longer history. Unknown markers are rendered in a high-visibility style so that absence of information is never mistaken for absence of risk.

20 Scalability Considerations

The architecture is designed for horizontal scaling of the API gateway, orchestrator workers, and AI service replicas. The relational store may become a bottleneck under very high concurrent emergency load; sharding by patient identifier range or migration of high-volume audit data to a time-series store are recognised future optimisations. Offline devices impose no server load until synchronisation occurs.

21 Regulatory Alignment Summary

CuraTrack is designed with awareness of the following instruments:

- Digital Personal Data Protection Act, 2023 (consent, legitimate use for medical emergencies, security safeguards, breach notification).
- ABDM Health Data Management Policy and FHIR Implementation Guides (consent manager concepts, FHIR R4 document types, federated data principles).

- EHR Standards for India (2016) as background context.

The paper makes no claim that the current design is certified, registered, or compliant under any of these regimes. Alignment is intentional and residual gaps are acknowledged.

22 Conclusion

CuraTrack aims to make critical patient information more accessible to authorised healthcare professionals, particularly when patients cannot communicate their medical history themselves. It combines structured medical records derived from patient-provided documents, specialised AI agents with explicit responsibilities and structured messaging, consent-based and purpose-limited sharing, deterministic safety controls that no large language model can override, and human medical oversight at every safety-critical decision point. The research contribution is a coherent multi-agent architecture, a fully specified non-LLM safety engine, a realistic emergency access model using protected QR identifiers and short-lived tokens, a threat model and mitigation set aligned with the DPDP Act 2023 and ABDM principles, and a reproducible evaluation protocol grounded in synthetic data. Substantial experimental measurement and clinical validation under appropriate ethics governance remain necessary before any claim of real-world clinical benefit can be advanced. The system is offered as a research design and methodological framework, not as a certified or deployed clinical product.

Acknowledgment

The authors thank the Department of Computer Science and Engineering, Rajalakshmi Engineering College, Chennai, for academic support. No external funding, institutional ethics approval, or clinical trial registration is claimed for the present design paper. Placeholders for supervisor names and contact emails are intentionally omitted pending institutional guidance.

References

[1] National Resource Centre for EHR Standards (NRCeS), "FHIR Implementation Guide for ABDM," version 7.0.0, 2026. [Online]. Available: https://nrces.in/preview/ndhm

[2] National Health Authority, Government of India, "Ayushman Bharat Digital Mission." [Online]. Available: https://abdm.gov.in

[3] NRCeS / C-DAC, "Implementation Guide for Adoption of FHIR in ABDM and NHCX," 2024.

[4] Government of India, "The Digital Personal Data Protection Act, 2023," Act No. 22 of 2023, Gazette of India.

[5] Sector analyses of DPDP Act applicability to hospitals, clinics, diagnostic laboratories and health-tech platforms (2025–2026), confirming Data Fiduciary status and legitimate-use exceptions for medical emergencies threatening life or health.

[6] A. Boukottaya et al., "Information extraction from electronic medical documents: state of the art and future research directions," *Knowledge and Information Systems*, 2022.

[7] Scoping literature reviews of natural language processing for medical text processing (2019–2025).

[8] "CLINES: Clinical LLM-based Information Extraction and Structuring Agent," recent clinical information-extraction pipeline literature, 2026.

[9] Operationalising large language models for clinical research data extraction: methods, quality control and governance, *Journal of Medical Systems*, 2026.

[10] Z. Yao and H. Yu, "LLM-Based Multi-Agent Systems for Clinical Workflows: A Survey of AI Hospitals," ACL, 2026.

[11] M. Moritz, E. Topol and P. Rajpurkar, "Coordinated AI agents for advancing healthcare," *Nature Biomedical Engineering*, vol. 9, pp. 432–438, 2025.

[12] A. Ibrahim et al., "TriAgent: An Adaptive Multi-Agent Architecture for Crisis Clinical Decision Support Under Incomplete Information," *AI*, vol. 7, no. 6, 230, 2026.

[13] E. Klang et al., "Orchestrated multi agents sustain accuracy under clinical-scale workloads compared to a single agent," *npj Health Systems*, 2026.

[14] "PHO-Agents: A Large Language Model–Powered Multi-Agent System for Predicting Health Outcomes," PMC / related clinical multi-agent literature.

[15] EHRAgent and related multi-agent frameworks for natural-language EHR querying and analytics (2024–2026 literature).

[16] HL7 International, "FHIR Release 4 (R4)," 2019. [Online]. Available: https://hl7.org/fhir/R4/

A Extended Safety Rule Catalogue

The complete catalogue of deterministic safety rules, including input/output schemas for every agent, sample synthetic evaluation datasets, and the full OpenAPI surface of the proposed services, is maintained in the project repository and is available to reviewers upon request. Selected additional rules include rate-limit enforcement, dual-control requirements for bulk export, and mandatory post-emergency access review flags.

B Evaluation Table Templates

Table 3: Document Extraction Performance (Pending Experiment)

Field Type	**Precision**	**Recall**	**F1**	**Notes**
Medication name	–	–	–	Pending
Dosage / frequency	–	–	–	Pending
Allergy	–	–	–	Pending
Diagnosis	–	–	–	Pending
Laboratory value	–	–	–	Pending

Table 4: Safety Rule Enforcement on Adversarial Suite (Pending Experiment)

Rule	**Correct Enforcement Rate**	**Notes**
R1 Unauthorised request	–	Target 100 %
R2 Unverified prescription	–	Target 100 %
R3 Conflict flagging	–	Target 100 %
R4 Authenticated SOS	–	Target 100 %
R5 Unknown field marker	–	Target 100 %
R6 Scope exceedance	–	Target 100 %
R7 Rate limit	–	Target 100 %
R8 Post-emergency review	–	Target 100 %

Table 5: Retrieval Latency and Completeness (Pending Experiment)

Scenario	p50 Latency	p95 Latency	Critical-Field Completeness
Routine clinician query	–	–	–
Emergency QR access	–	–	–
Offline local summary	–	–	–

C Synthetic Data Generation Notes

All evaluation datasets are generated synthetically. Medication names, dosages, allergy lists, and laboratory values are drawn from controlled vocabularies and randomised within clinically plausible ranges. Document images for OCR testing are produced by rendering synthetic prescriptions and laboratory reports and optionally applying realistic noise, skew, and handwriting simulation. No real patient identifiers or clinical records are used at any stage.